

Which tools may your AI agent use?

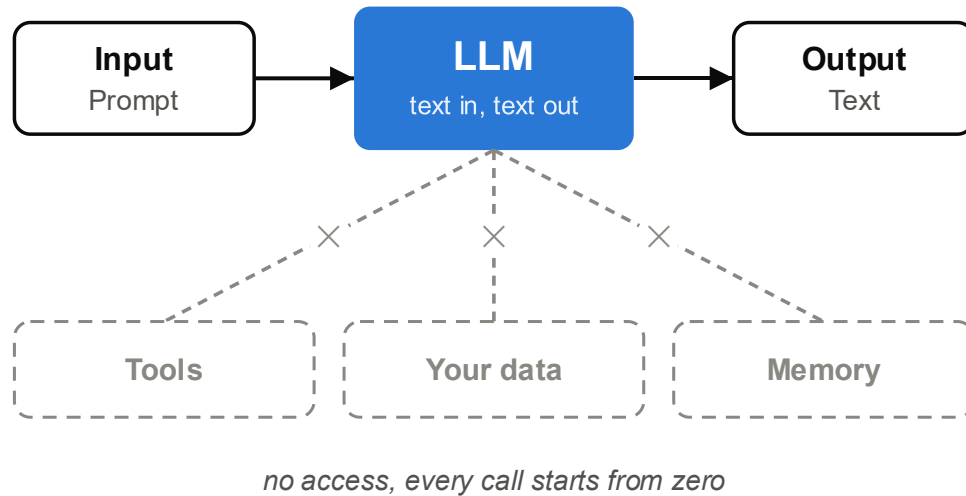
MCP in practice: finding use cases and vetting servers safely

Jill Barvencik · David Goll
AI Service Center Berlin-Brandenburg (HPI)
September 9, 2026

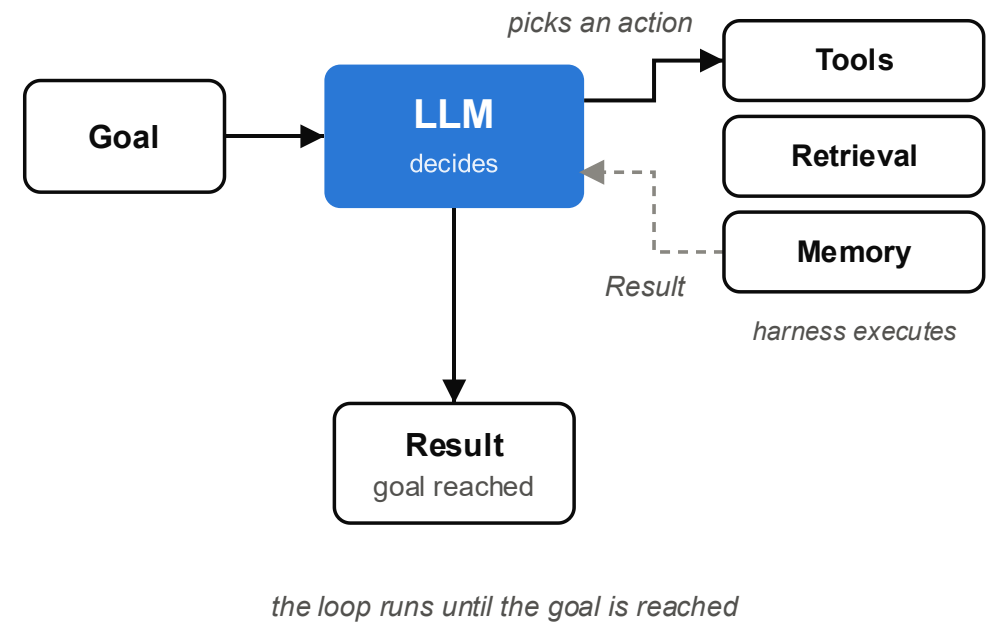
20 min concepts → 10 min example → 20 min your own use case → 10 min discussion

What is an agent?

The LLM on its own

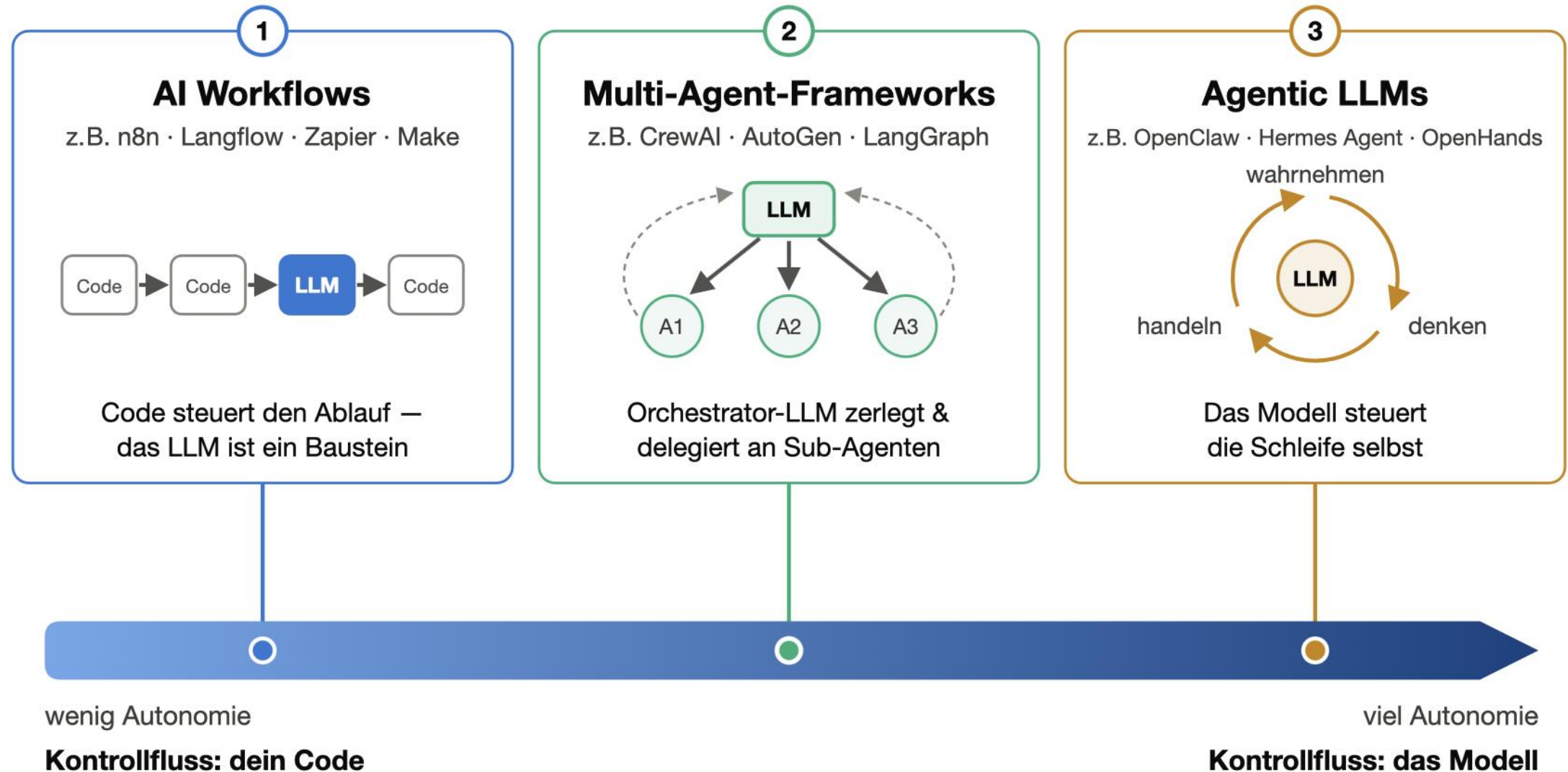


The agent

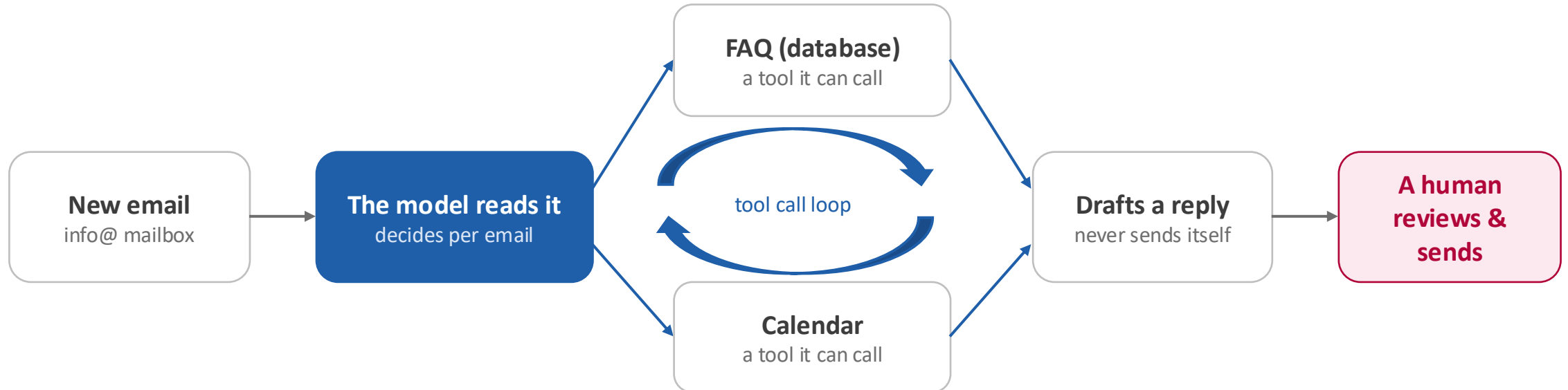


“An LLM agent runs tools in a loop to achieve a goal.”

Three kinds of “AI agents” (LLM)



Example: email AI assistant



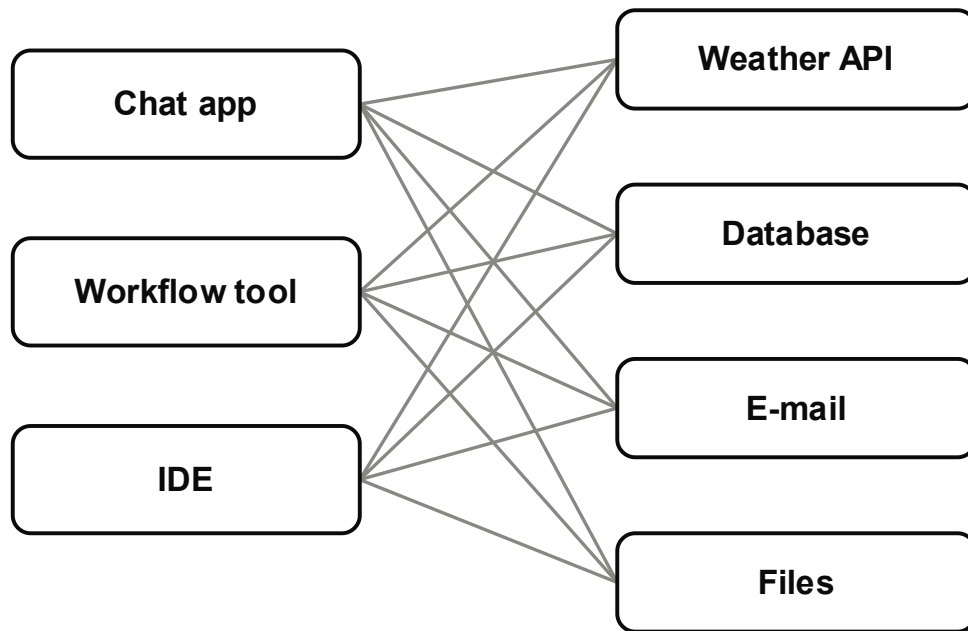
→ **Category 1 or 3**

(depending on how much decision-making power is left to the model)

Model Context Protocol (MCP)

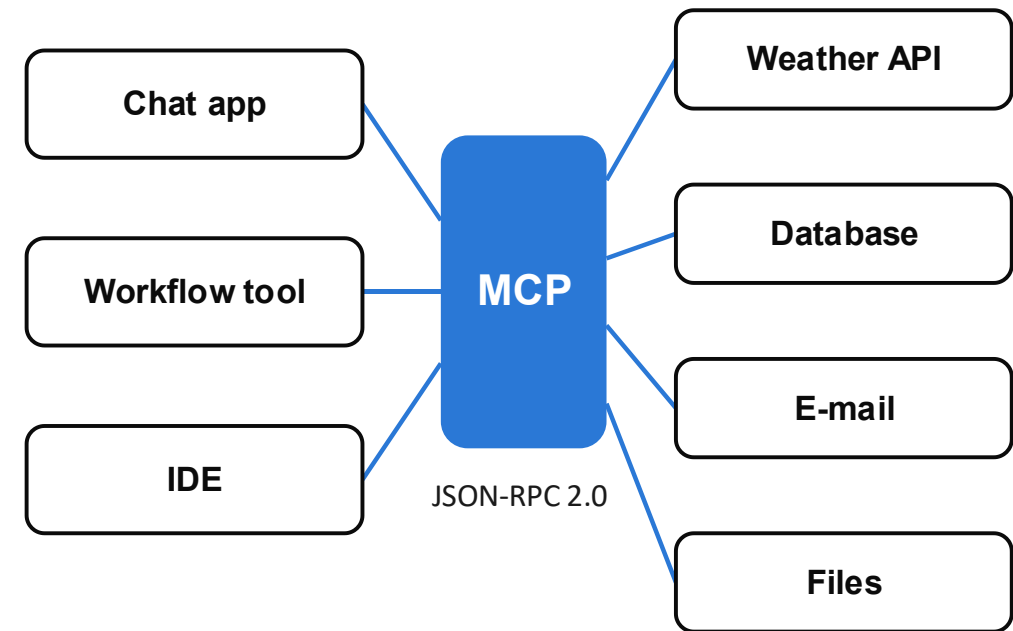
MCP is an open-source standard for connecting AI applications to external systems.
“A USB-C port for AI applications.”

Without MCP



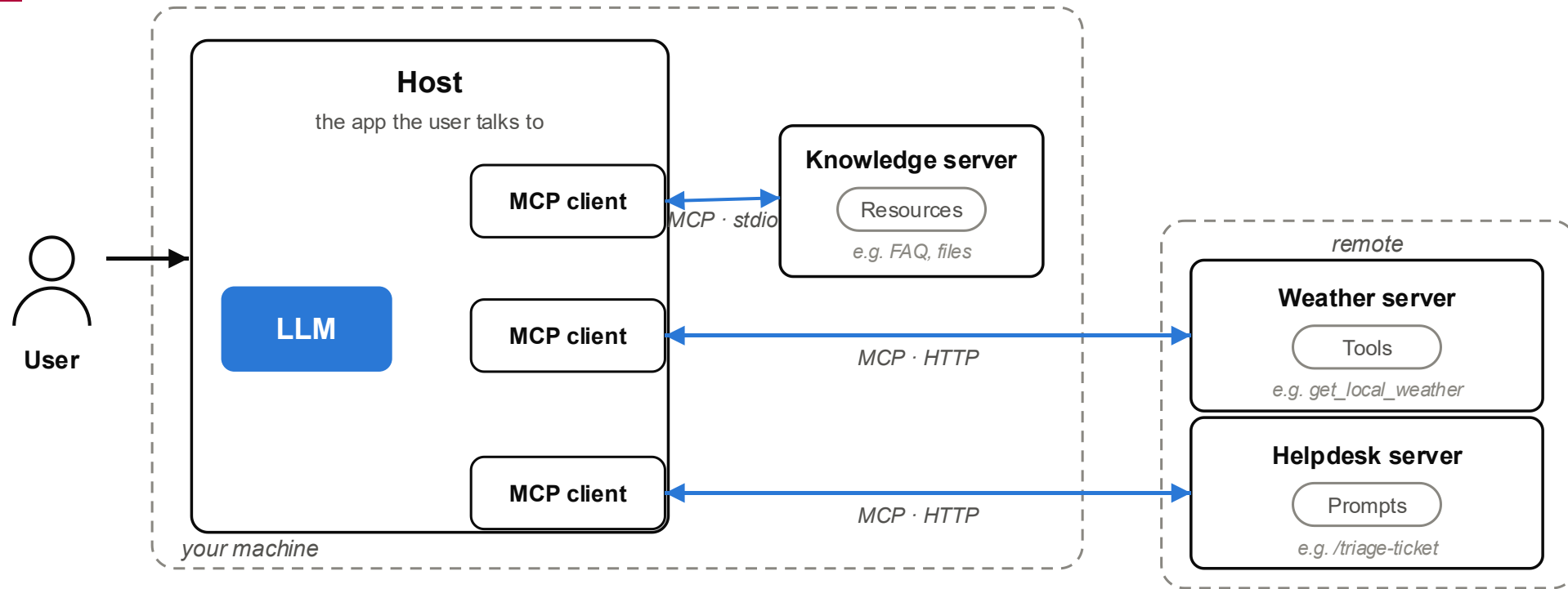
$3 \times 4 = 12$ point-to-point integrations

With MCP



$3 + 4 = 7$ connections, one protocol

How MCP works



Building block	What the server offers	Example
Resources	Data it can read	Files, databases, ...
Tools	Actions the model can call	<code>get_local_weather</code> , <code>draft_email</code> , ...
Prompts	Predefined workflows	"summarize & triage this ticket"

How does the model choose a tool?

```
name:         get_forecast
description:   "Daily weather forecast for a city. Use for
               questions about rain, temperature or wind
               on a specific date."
inputs:       city (text), date (date)
```

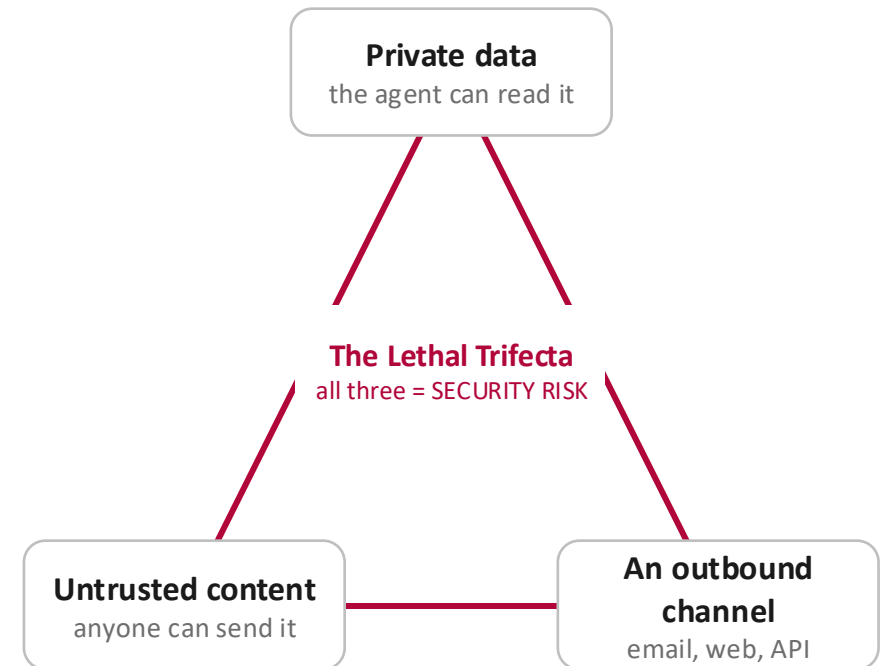


Descriptions and everything a tool returns are text that steers your agent.

Security: who do you trust?

A connected server acts with the permissions you gave it.

Risk	What can happen
Excessive permissions	the server gets an admin token although it only needed to read
Exposed secrets	an API key sits in plain text in a config file
Prompt Injection	an incoming email hides instructions, and the agent executes them
Tool Poisoning	a tool description hides instructions nobody sees in the UI
Rug Pull	a vetted server changes its tool descriptions after an update
Supply Chain	a server impersonates a known provider and BCCs every email to a third party



Never combine more than two of these capabilities!

What can go wrong?

May 2025 · GitHub MCP *demonstrated*

A malicious public issue tricks an agent into copying data from a private repo into a public pull request.

Prompt injection + overly broad token

Source: Invariant Labs
<https://invariantlabs.ai/blog/mcp-github-vulnerability>

Sep 2025 · postmark-mcp *in the wild*

A fake email server behaves normally for months, then quietly BCCs every email to an external address.

Supply Chain

Source: Koi Security
<https://thehackernews.com/2025/09/first-malicious-mcp-server-found.html>

2025 · MCPoison · CVE-2025-54136 *in the wild*

An already approved MCP config is modified afterwards; code runs without re-approval.

Rug pull on a trusted config

Source: Check Point Research
<https://research.checkpoint.com/2025/cursor-vulnerability-mcpoison/>

Three different failure modes: a hijacked agent · a malicious server · a trusted config changed unnoticed.

Limiting the risks

- 1 Least privilege** the agent gets its own account, minimal scopes, short-lived keys.
- 2 Sandbox** run local servers in a Docker container: limits what the process can reach (file system, network, system) if it misbehaves.
- 3 Human in the loop** a human approves everything irreversible: send, delete, pay, publish.
- 4 Rule of Two (Meta)** at most 2 of the 3 trifecta properties per agent; the third only behind an approval.
- 5 Trust the source** prefer verified or first-party servers; treat updates like software updates.
- 6 Keep logs** if something goes wrong, you want to know what the agent did.

Assume the agent can be hijacked, and make that survivable.

MCP security checklist

Question

- 1 **Who provides it?** first-party · verified · unknown
 - 2 **What can it do on your behalf?** read-only vs. irreversible
 - 3 **Where does your data go?** local code vs. remote cloud
 - 4 **Does the combination become dangerous?** Trifecta / Rule of Two
 - 5 **Could you live with the worst case?**
-

Verdict →



use



use with conditions



not in this context

Tools: official registry · MCP Inspector · mcp-scan

A listing is not a security certification.

How do I find an MCP server?

Official registry

registry.modelcontextprotocol.io

maintained by the MCP project,
(hard to navigate)

Large catalogs

- pulesemcp.com (+ use cases)
- github.com/mcp
- mcpservers.org
- smithery.ai

browse by provider, category,
and popularity

Catalogs with security ratings

- mcpsafe.org
- mcprisk.org

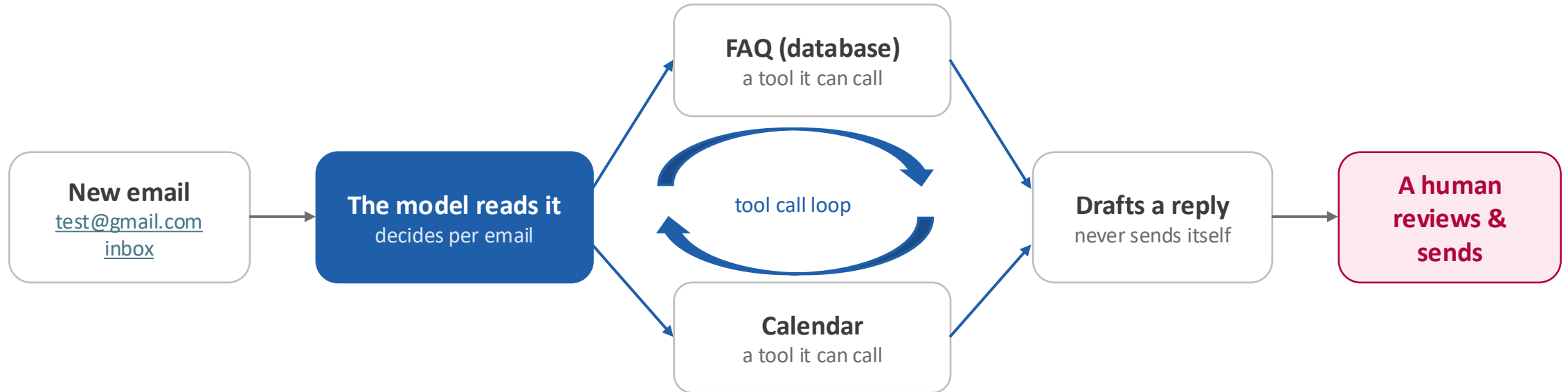
Official vendor servers

- Google
- Notion
- Figma
- Scalable Capital
- ...

Vendors increasingly ship their
own servers

First question for every use case: does an official server exist?

Demo: Connect Claude with Gmail and Google Calendar



Demo · Step 1: find and assess servers

Directory / Gmail

Copy link X



Gmail 
Draft replies, summarize threads, & search your inbox

Connect to Claude

Connect Gmail to Claude to quickly find important emails and understand long conversations. Claude can search through your messages, read entire email threads to give you context, and help you stay on top of your inbox. Perfect for finding that message you remember sending, catching up on email chains you missed, or preparing for meetings.

Tools

apply_sensitive_messa...

forward

list_filters

apply_sensitive_thread...

get_message

list_labels

create_draft

get_thread

mark_message_spam

create_filter

label_message

mark_thread_spam

create_label

label_thread

reply

delete_label

list_drafts

search_threads

Show all

CATEGORY

Communication

MADE BY

[Google](#) 

SIGN-IN

Required

CONNECTOR URL

<https://gmailmcp.googleapis.com/mcp/v1>

ADDED

March 2026

MORE INFO

[Documentation](#) 

[Support](#) 

[Privacy Policy](#) 

 Only use connectors from developers you trust. Anthropic does not control which tools developers make available and cannot verify that they will work as intended or that they won't change.

What to look for

Who built it?

Checklist Q1

What can it do on your behalf?

Checklist Q2

Demo · Step 2: connect with least privilege

A · Gmail permission dialog

Über Google anmelden



Claude for Gmail möchte auf Ihr Google-Konto zugreifen

 kisz.test@gmail.com

Wählen Sie aus, worauf **Claude for Gmail** zugreifen darf

 Alle auswählen

-  E-Mails und Einstellungen abrufen. ☒ [Zugriffsdetails ansehen](#)
-  Entwürfe verwalten und E-Mails senden. ☒ [Zugriffsdetails ansehen](#)
-  E-Mails über Ihr Gmail-Konto aufrufen, verfassen und senden. ☐ [Zugriffsdetails ansehen](#)

Claude for Gmail vertrauen?
In der [Datenschutzerklärung](#) und den [Nutzungsbedingungen](#) von Claude for Gmail erfahren Sie, wie Claude for Gmail Ihre Daten verarbeitet und schützt.
Sie können in Ihrem [Google-Konto](#) jederzeit Änderungen an Ihren Angaben vornehmen.
Google unterstützt Sie dabei, [Daten sicher zu teilen](#).

Abbrechen

Weiter

Deutsch ▾

[Hilfe](#) [Datenschutz](#) [Nutzungsbedingungen](#)

B · Google Calendar permission dialog

Über Google anmelden



Claude for Google Calendar möchte auf Ihr Google-Konto zugreifen

 kisz.test@gmail.com

Wählen Sie aus, worauf **Claude for Google Calendar** zugreifen darf

 Alle auswählen

-  Termine in allen Kalendern abrufen. ☒ [Zugriffsdetails ansehen](#)
-  Alle Kalender aufrufen und herunterladen, auf die Sie über Ihren Google Kalender Zugriff haben. ☐ [Zugriffsdetails ansehen](#)
-  Alle Kalender, die über Google Kalender verfügbar sind, aufrufen, bearbeiten, freigeben und endgültig löschen. ☐ [Zugriffsdetails ansehen](#)

Claude for Google Calendar vertrauen?
In der [Datenschutzerklärung](#) und den [Nutzungsbedingungen](#) von Claude for Google Calendar erfahren Sie, wie Claude for Google Calendar Ihre Daten verarbeitet und schützt.
Sie können in Ihrem [Google-Konto](#) jederzeit Änderungen an Ihren Angaben vornehmen.
Google unterstützt Sie dabei, [Daten sicher zu teilen](#).

Abbrechen

Weiter

Deutsch ▾

[Hilfe](#) [Datenschutz](#) [Nutzungsbedingungen](#)

Grant only what the task needs. Gmail: read + draft. Calendar: read only.

Demo

The screenshot shows an email interface with two messages. The first message is from 'customer test' to 'an mich' (me), dated 'Fr., 4. Sept., 09:59 (vor 3 Tagen)'. The second message is from 'test kisz' to 'an customer.kisz.test', dated 'Fr., 4. Sept., 11:03 (vor 3 Tagen)'. The second message contains a red line pointing to a footer note.

customer test <customer.kisz.test@gmail.com>
an mich ▾
Hallo,

wir sind ein kleines Unternehmen aus Potsdam und interessieren uns für KI-Schulungen.

Bieten Sie so etwas auch für Einsteiger an, und was würde das kosten?

Viele Grüße,
Max Mustermann

Fr., 4. Sept., 09:59 (vor 3 Tagen) ☆ 😊 ↩ ⋮

test kisz <kisz.test@gmail.com>
an customer.kisz.test ▾
Guten Tag Herr Mustermann,

vielen Dank für Ihre Anfrage. Ja, wir bieten Workshops für Einsteiger an, auch für kleine Unternehmen und KMU. Das Angebot reicht von einsteigerfreundlichen Formaten bis hin zu Workshops zur Entwicklung eigener KI-Anwendungen.

Alle unsere Angebote sind kostenlos.

Eine Übersicht unserer aktuellen Veranstaltungen und die Möglichkeit zur Anmeldung finden Sie hier: [Workshops und Veranstaltungen](#).

Falls Sie vorab Fragen haben oder unsicher sind, welches Format am besten passt, können Sie gern an unserer [KI-Sprechstunde](#) teilnehmen. Die findet online in kleinen Gruppen statt und dient zum Kennenlernen.

Bei weiteren Fragen melden Sie sich gern.

Mit freundlichen Grüßen
KI-Servicezentrum Berlin-Brandenburg

Dieser Entwurf wurde mit KI-Unterstützung erstellt. Ein Teammitglied hat den Inhalt geprüft und die E-Mail abgeschickt.

...

Human-In-The-Loop

Unread emails -> agent

- Question → FAQ answer
- Booking → calendar → free slot
- otherwise → escalate

Only drafts are created!

Your turn: design your own agentic workflow

About 20 minutes · pen and paper

- 1 **Pick a recurring task**
- 2 **Fill in the worksheet** idea, 2–3 example requests, why an agent?, why an MCP server?
- 3 **Find suitable MCP servers** registry.modelcontextprotocol.io, pulse.mcp.com, github.com/mcp, mcp-servers.org, smithery.ai, mcp-safe.org, mcp-prisk.org, ...
- 4 **Run each server through the checklist** Verdict ●●●
- 5 **Note next steps toward a pilot** owners · access · approval

Afterwards: 3-minute pitches. Your idea, your server(s), your verdict.

kisz@hpi.de

hpi.de/kisz

Your opinion is
relevant!



QR code to feedback form

Gefördert durch:

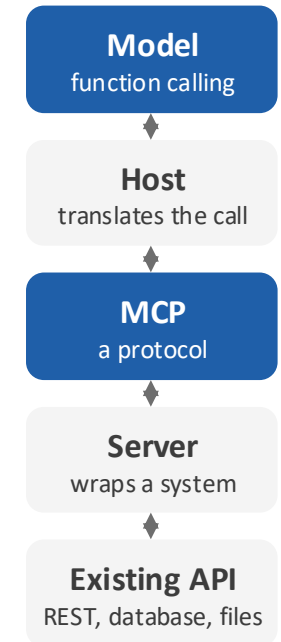


Bundesministerium
für Forschung, Technologie
und Raumfahrt



Backup · Isn't this just another API?

	Classic API (REST, gRPC)	MCP
Contract	one per service, each different	one fixed interface for every tool
Integration	at development time: read docs, write glue code	at runtime: tools/list → model context
User	a developer	the model, reading descriptions



Underneath it is JSON-RPC; the model still does ordinary function calling, so any model works.

Precedents: LSP (editors × languages), ODBC (apps × databases). A server usually wraps an existing API: MCP sits in front of your services, it does not replace them.

Backup · What actually goes over the wire

1 · Discovery: `tools/list`

```
// request
{ "method": "tools/list" }

// response
{ "tools": [ {
  "name": "get_forecast",
  "description": "Daily weather forecast
    for a city. Use for ...",
  "inputSchema": { "city": "string",
    "date": "string" }
} ] }
```

2 · Execution: `tools/call`

```
// request
{ "method": "tools/call",
  "params": { "name": "get_forecast",
    "arguments": { "city": "Berlin",
      "date": "2026-09-05" } } }

// response
{ "content": [ { "type": "text",
  "text": "Berlin, 5 Sept: 19 °C, light rain" } ] }
```

Plain JSON-RPC · discovery at runtime · the description is a prompt.

inputSchema is ordinary JSON Schema. The host passes name, description, and schema to the model in its native function-calling format; the model never sees MCP itself.

Under the hood: MCP speaks JSON

Every message between client and server is a JSON object (standard: JSON-RPC 2.0).

```
→ { "method": "tools/list" }    // What can you do?
← { "tools": [ { "name": "get_local_weather",
  "description": "Weather forecast for a city ...",
  "inputSchema": { "city": "string", "date": "string" } } ] }

→ { "method": "tools/call",    // Please execute
  "params": { "name": "get_local_weather",
    "arguments": { "city": "Berlin", "date": "2026-09-09" } } }
← { "content": [ { "type": "text",
  "text": "Berlin, 9 Sept: 19 °C, light rain" } ] }
```

- **Language-independent** – any client talks to any server (Python, TypeScript, Go ...)
- **Structured & verifiable** – parameters are typed via JSON Schema, the model produces valid calls
- **Fits function calling** – LLMs already speak JSON Schema, so it maps 1:1
- **Human-readable** – directly traceable in MCP Inspector

The model does not write JSON-RPC – the host translates between model call and protocol.